Studio Nx

백엔드 154 — request_password_reset()

2026-10-14

백엔드 154 — `request_password_reset()` (재설정 요청)

항목	내용
파일	`studionx/backend/app/services/password_reset_service.py`, 설정 `core/config.py`(`mail_backend`, `app_base_url`), `studionx/.env.example`
작업	P1-28 비밀번호 찾기 (FR-118): 다섯 번째 함수 (`mask_email()` 도우미 포함)
작성	Claude (AI), 2026-10-14, 사용자 검토
이전	153 `check_reset_rate_limit()`
시험	`tests/test_password_reset_service.py`의 13개 (이 파일 전체 29개)
다음	`reset_password()`: 토큰과 새 비밀번호로 비밀번호를 바꾸고 이전 로그인을 무효로 만듦

1. 하는 일

재설정 요청을 처리합니다. **가입 여부와 관계없이 항상 같은 결과(`None`)**를 돌려줘서, 응답으로 가입 여부를 알아낼 수 없습니다.

순서	일
1	`check_reset_rate_limit()`으로 횟수를 검사합니다. 넘으면 429입니다
2	이메일(소문자, 공백 제거)로 회원을 찾습니다. 없거나 `ACTIVE`가 아니면(탈퇴, 정지) 아무것도 하지 않고 끝냅니다
3	`ACTIVE`이면 `create_reset_token()`으로 토큰을 만들고, 링크를 메일(지금은 서버 로그)로 보냅니다

링크의 모양은 `http://localhost:8000/resetPassword.html#token=<토큰 원문>`입니다.

2. 코드 (요약)

```
def request_password_reset(db: Session, email: str, ip: str | None) -> None:
    check_reset_rate_limit(ip, email)

    user = db.scalar(select(User).where(User.email == email.strip().lower()))
    if user is None or user.status != UserStatus.ACTIVE:
        return

    settings = get_settings()
    if settings.mail_backend != "log":
        logger.warning("password reset requested but mail is not configured (MAIL_BACKEND)")
        return

    token = create_reset_token(db, user)
    link = f"{settings.app_base_url.rstrip('/')}/resetPassword.html#token={token}"
    logger.info("[DEV MAIL] password reset link for %s: %s", mask_email(user.email), link)
```

3. 개인정보와 보안 판단

사용자가 "개인정보적으로 문제가 없으면 그렇게 하라"고 하셔서 문제 지점을 따져 보고 아래와 같이 막았습니다.

우려	처리
토큰이 접속 기록과 Referer로 새는 것	토큰을 `?token=`이 아니라 `#token=` 뒤에 둡니다. `#` 뒤의 값은 브라우저가 서버로 보내지 않아서 서버 접속 기록, 프록시 기록, 다른 사이트로 가는 `Referer`에 남지 않습니다
로그에 이메일이 남는 것	이메일을 가려서 남깁니다(`real@example.com` → `r***@example.com`)
로그에 링크가 남는 것 (링크 = 비밀번호를 바꿀 수 있는 값)	**개발용(`MAIL_BACKEND=log`)일 때만** 출력합니다. 그 밖의 설정이면 토큰도 링크도 만들지 않고 "메일 설정 없음"만 기록합니다. 배포에서 실수로 이 방식이 켜져 있어도 `log`가 아니면 링크가 남지 않습니다
응답으로 가입 여부가 드러나는 것	항상 같은 결과를 돌려주고, 횟수 제한도 가입 여부와 관계없이 셉니다
탈퇴, 정지 계정	가입된 주소여도 조용히 아무것도 하지 않습니다(`ACTIVE`만 처리)
링크가 오래 살아 있는 것	30분 유효, 한 번만 사용, 다시 요청하면 이전 링크가 무효

배포 전 남은 일(문서에 남깁니다).

1. SMTP 같은 실제 메일 발송을 붙이고 `MAIL_BACKEND`를 그 값으로 바꿔야 합니다. 그 전에는 배포에서 재설정이 동작하지 않습니다(안전한 쪽으로 실패).
2. `resetPassword.html`은 `#token=`을 읽은 뒤 주소창에서 지우고(`history.replaceState`) `Referrer-Policy: no-referrer`를 두어야 합니다. 화면 작업 때 반영합니다.
3. 개인정보 처리방침(`privacy.html`, 세 판)에 "비밀번호 재설정 메일 발송"과 처리 항목을 반영하는 일은 정식 공개 전 검토 때 함께 합니다.

4. 시험 (13개 추가, 파일 전체 29개 통과)

확인	결과
`ACTIVE` 회원은 로그에 링크가 나오고 해시가 저장됨, 링크의 `/`가 겹치지 않음	✓
토큰이 `?`가 아니라 `#` 뒤에 있음	✓
로그에 이메일이 가려져 있고 원문 이메일은 없음	✓
이메일의 대소문자와 공백을 무시하고 찾음	✓
없는 이메일은 아무것도 만들지 않고 같은 결과	✓
탈퇴, 정지 회원은 아무것도 만들지 않고 같은 결과 (2개)	✓ ✓
없는 이메일에도 횟수 제한이 똑같이 적용됨	✓
두 번째 요청이 첫 링크를 무효로 만듦	✓
`MAIL_BACKEND`가 `log`가 아니면 토큰도 링크도 만들지 않음	✓
`mask_email` (3가지)	✓

시험을 확인하는 시험. 일부러 틀리게 바꿔 시험이 잡는지 보았습니다.

- 상태 검사를 지우자 2개 실패
- `#token=`을 `?token=`으로 바꾸자 2개 실패
- 이메일 가리기를 지우자 1개 실패

- `mail_backend` 검사를 지우자 1개 실패
- 모두 되돌린 뒤 통과했습니다.

전체 pytest 730개 통과, `ruff` 통과.